

SAMM Interview Questions Example

This example presents open-ended questions designed to trigger conversations that cover the range of SAMM questions as much as possible. You need to keep the SAMM assessment sheet at the side as a checklist, to see if you need to ask additional questions.

The scenario for these questions is an interview with a development team. The questions follow the order of the SAMM assessment sheet 2.0, but with a slight change for a more natural flow. Concretely, Education & Guidance comes after Secure Architecture.

1. Tell us about the input instructions, policies, standards or any other documentation that you get from the organization regarding security?
 - a. How does the organization deal with risks and threats? What assets and data are important and how?
 - b. How is that security documentation accessible? Is there anything else information-wise that you might need and that is not currently available?
 - c. What is the organization's strategic plan for dealing with application security? More specifically, you can ask about concepts like risk appetite, business priorities, roadmap, budgets, etc? Is there a buy-in from all stakeholders including the teams?
 - i. When was the last time the plan was reviewed and updated?
 - ii. How do you know it is a good plan? Are there any KPIs security-wise? (This question tries to look for metrics, how they are measured and where they are published. Furthermore the strategy and the roadmap are hopefully based on the KPIs and updated based on the results).
 - d. How about organizational policies and standards?
 - i. Describe how you interpret / implement these from a specific technology perspective.

- ii. How do you ensure the organizational policies and standards are actually implemented? (Looking for test scripts / run-books / tools either manual or automated)
 - iii. Do you need to report back whether the applications are compliant with these policies and standards? How do you do that?
 - iv. Do you have any external obligations (e.g., GDPR, ISO27001, SOC2, etc)? How do you deal with these? (looking for any translation of these to requirements).
 - e. How does the organization deal with the inherent business risks of an application? For example, an intranet-facing app for calculating the holidays is obviously not as critical as a SaaS application that generates a substantial portion of the organization's revenue.
 - i. Is there any documentation of this risk profile per application?
 - ii. Does the team know about these and can they access these profiles?
 - iii. When was the last time it was updated?
2. Moving on to technical risks, how do you deal with risks and threats in a given application?
- a. What approach do you use? Is there a checklist-based threat modeling approach or just a brainstorming session?
 - b. Is there training for such a risk/threat modeling activity?
 - c. What is the output of this exercise?
 - d. When do you threat model in your SDLC?
 - e. When was the last time you reviewed a threat model? (Do you review the models regularly?)
3. How do you deal with requirements in general and security requirements in specific? Do teams come up with requirements themselves and based on what input?
- a. Could you please show some examples?
 - b. We're curious to understand who is involved in the requirements process?
 - c. Are the requirements aligned with the organization baseline (e.g., a password should be 12 characters long and not be found in a dictionary attack)?

- d. Any chance you leverage a standard framework to assist (e.g., ASVS)?
- 4. Do you have any third parties building software for you? If yes, what do you require of them?
 - a. Do you have a standard list of requirements / questions for selecting the third party?
 - b. How does the agreement with the third party look like? Is there anything about security requirements and processes in that agreement?
 - c. Do you base your agreements on a standard template?
 - d. How do you check the security quality of the software the third party has delivered?
 - e. On a scale of 1 to 10 how good is the secure SDLC of this third party?
- 5. How do you deal with security requirements on an architectural level? Do you have any standard and reusable security building blocks or services?
 - a. Do you have a list of high-level security principles that the team knows and leverages (e.g., defense in depth, no secret sauce, etc.)
 - b. When you develop new applications, how do you build the architecture? Do you start from a reference architecture or teams are improvising every time?
 - c. Is there a list of available building blocks / services that you can simply reuse in every application (e.g., authentication module / service, sanitization service, etc). Also, do you have the necessary knowledge accessible to use these (e.g., if you have to plug in the sanitization service, is there someone you can ask for help who knows it)?
- 6. What technologies do you use? How about the security risks of those technologies (e.g., barebone frameworkless PHP applications like WordPress are horribly insecure)?
 - a. Can you use any technology you would like to?
 - b. Is there any automated enforcement of the recommended list of technologies if any?
- 7. How do you make sure that everyone is aware of security in terms of training?
 - a. What trainings do you provide to whom and when was the last time the training curriculum was updated?

- b. Is the training for everyone? Is it consistent and mandatory?
 - c. Is there any customization towards different roles?
 - d. Is there a learning management system to track the completion of the courses?
- 8. Do you have security champions in the teams?
 - a. What do they do?
 - b. Is the process smooth and what would you change?
- 9. Do you have a security team / center of excellence?
 - a. What is its charter and what do they do?
 - b. Is there any material they publish and how is it accessible / searchable for everyone in the organization?
 - c. Is the security team effective and how could it be further improved?
- 10. How do teams share AppSec information?
 - a. Is there a portal / slack channel? How do you make sure people actually read it (especially in large organizations things might be communicated with massive amounts of emails ending up in nobody reading them)?
 - b. What information is shared? Tool updates? Standard changes? Metrics?
 - c. How well does it work on a scale from 1 to 10 and how would you make it better?
- 11. Could you describe your build process?
 - a. How do you harden / secure the process and the tools? Can anyone tamper with them?
 - b. How do you store the build-time secrets?
 - c. How much human interaction is required in the build process?
 - d. Do you have any security checks in the build? What tools do you leverage? Are the tools effective?
 - e. Do the tools break the build when they find any vulnerabilities? When do you accept a build and when not?
 - f. Do you log the warnings and failures?
 - g. How often do you reconfigure and reconsider the tools?
- 12. How do you deal with third party dependencies?

- a. How do you deal with vulnerable dependencies?
- b. How about outdated or no longer maintained dependencies?
- c. How about the legal (licensing) aspect?
- d. What happens to the build process if there is a vulnerability found in one of the third party libraries?
- e. Which tools do you leverage for third-party dependency monitoring?
- f. When a developer decides to add a new dependency, is there any approval process behind it?

13. Could you describe your deployment process?

- a. How is the process hardened?
- b. How much human interaction is required in the deployment process?
- c. What happens if vulnerabilities are identified during the deployment?
- d. How do you make sure that what you deploy is actually what you have produced in your build process (integrity of the deployed artifacts)?
- e. How do you deal with production secrets? Who has access to them and is there any monitoring for suspicious events / access?
- f. Can the source code end up containing secrets?
- g. How do your secrets end up in configuration files?
- h. How frequently are the secrets changed?

14. How do you track defects in your landscape?

- a. Do you have a registry for it?
- b. How do you classify your known weaknesses in type and in severity?
- c. What are the sources?
- d. Is there an SLA on these defects? Or do you have KPIs/metrics?
- e. How is follow-up on defects enforced?

15. How and when do you review your architecture for security?

- a. Who does it and how?
- b. Do you have any standardized security requirements for that?
- c. Do you track the findings?
- d. Do you approach it from the perspective of standard threats, or maybe threats identified from threat assessment?

- e. Do you also review the effectiveness of controls in that architecture? How?
- f. And do you update your reference architecture based on findings?

16. What is your security testing policy?

- a. When are tests executed?
- b. What part of the tests is automated and what part is not? For instance, how does the QA know what to test?
- c. What frameworks / tools / languages do you leverage (test suits, DLSs, DAST, SAST, fuzzing)?
- d. When do you translate bugs into regression tests?
- e. Do you have a set of predetermined threats (abuse cases) to test against?
- f. How about stress tests / denial of service?
- g. How is security testing performed during build and deployment? What do you do with the findings?
- h. How about manual review? Who, when and how do you perform it? Any checklists?
- i. How about pentesting: when, how and who? Any specific test cases?
- j. How do you use findings from testing to improve the development process/training?

17. Do you analyze logs for security incidents? What is the process of handling them (document, respond, root cause analysis)? Always ask how, by whom and when.

- a. How formal are these detection and handling processes (owner, documented)?
- b. When was the last time these processes were reviewed/updated?
- c. How informed are people (training checklist)?
- d. Do you have incident classification?
- e. How about forensic analysis tooling?
- f. Is there an incident response team?

18. How do you make sure your key techstack components are configured securely (e.g., container configurations, linux machines, etc).

- a. Are there any baselines in place and who maintains them?
- b. Is there training for this?

- c. How do you monitor conformity with baselines (automated)?
- 19. What is your process of keeping components up-to-date?
 - a. Do you have an SBOM and how do you check for vulnerabilities?
 - b. Is there an SLA in place
 - c. How do you review and update this process?
- 20. How do you keep track of what data is stored where, and the sensitivity levels?
 - a. Do you leverage a data catalog?
 - b. Do you include regulation
 - c. How do you prevent production data getting into acceptance and testing?
Who has access to the production data?
 - d. Are there any controls in place to protect data in its lifecycle?
 - e. How do you deal with backups and most importantly their timely deletion?
 - f. Do you audit and review the data catalog, policies and procedures?
- 21. What happens when applications or services become end-of-life?
 - a. How do you know which applications are still in use?
 - b. How do you review applications and services with respect to the life state and estimations?